4ª EDIÇÃO

UMC SUMMIT

PESQUISA • INOVAÇÃO • EXTENSÃO

Health In Sight: portal de informação em saúde com autenticação segura e conformidade com a LGPD

Cassiano Jesus Silva, Guilherme da Silva Bonifácio, Yan Baumgarten Costa

Orientador: Prof. Dr. Fabiano Bezerra Menegidio

Sistemas de Informação · Universidade de Mogi das Cruzes (UMC)

Acesse o sistema

INTRODUÇÃO

Quem pesquisa um sintoma na internet encontra muito conteúdo sem fonte e listas que parecem dar um diagnóstico. E o que a pessoa pesquisa sobre saúde é dado sensível pela LGPD (art. 5º, II). Por isso, criamos um portal com fontes oficiais e com segurança desde o começo (OWASP, 2021).

OBJETIVO

Desenvolver um portal web informativo de saúde, que não faz diagnóstico, com autenticação em duas etapas, criptografia dos dados, recuperação segura de senha, trilha de auditoria e respeito aos direitos do titular previstos na LGPD.

METODOLOGIA

- Levantamos os requisitos funcionais e não funcionais a partir do checklist da disciplina.
- Desenvolvemos em Python 3.12 e Django 5.2, com MySQL 8 no Aiven e hospedagem no Render.
- Analisamos as ameaças com o modelo STRIDE e montamos uma matriz de riscos.
- Organizamos as tarefas em Kanban e entregamos o projeto em versões (releases) no GitHub.
- Testamos com 162 testes automatizados e varreduras de segurança a cada commit.

FLUXO DE AUTENTICAÇÃO

1. Cadastro
nome, e-mail, senha e aceite da política

↓

2. E-mail e senha
conferência do hash Argon2id

→ **5 senhas erradas** — bloqueio de 5 min, que dobra

↓

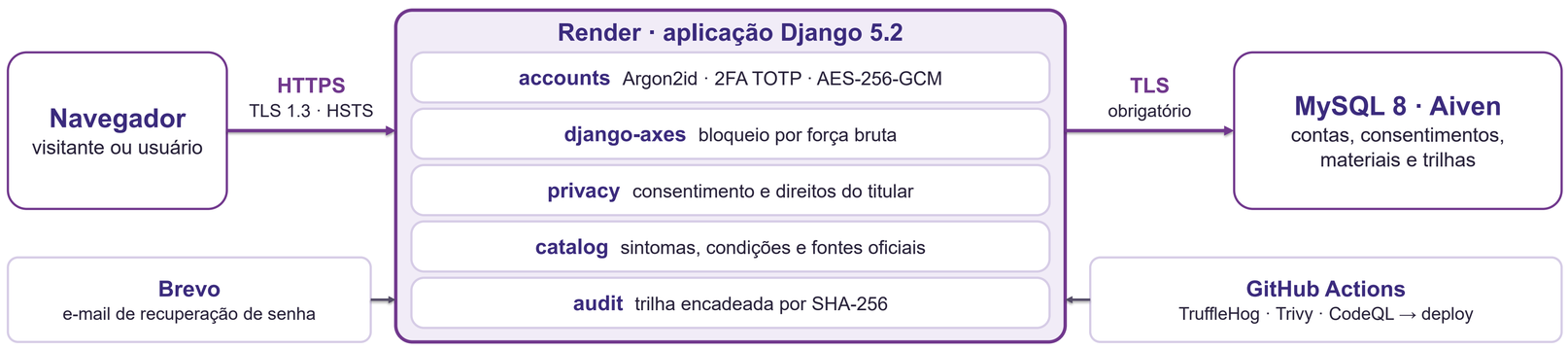
3. Código TOTP
6 dígitos, se o 2FA estiver ativo

↓

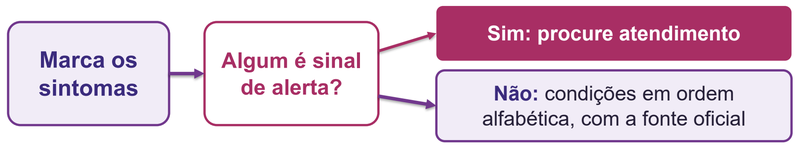
4. Sessão criada
15 min; cookies Secure e HttpOnly

Cada login, erro, uso do 2FA e bloqueio fica registrado na trilha de auditoria

ARQUITETURA DO SISTEMA



COMO FUNCIONA A CONSULTA

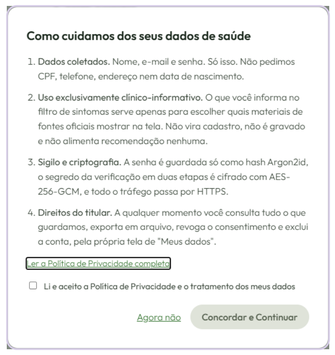


Sinais de alerta interrompem a busca. Nada do que é marcado fica gravado.

MECANISMOS DE SEGURANÇA

Requisito	Como fizemos
Hash de senha	Argon2id (64 MiB, t = 3, p = 2) e salt único (RFC 9106)
Segundo fator	código TOTP de 6 dígitos (RFC 6238); segredo cifrado em AES-256-GCM
Sessão e bloqueio	sessão de 15 min; 5 senhas erradas bloqueiam a conta por 5 min, o dobro se repetir
Recuperação	token de 256 bits, uso único e 30 min; só o SHA-256 é salvo
Em trânsito	HTTPS com TLS 1.3 e HSTS; TLS também até o banco
Auditoria	cada evento guarda o hash SHA-256 do anterior (Schneier; Kelsey, 1999)

CONFORMIDADE COM A LGPD



Aviso de privacidade exibido no cadastro

Minimização (art. 6º, III): só nome, e-mail e senha; a busca por sintomas não grava dados.

Finalidade (art. 8º, §4º): aceites separados para a conta e para guardar materiais, com data e versão.

Revogação (art. 8º, §5º): revogar apaga os materiais; excluir a conta revoga tudo.

Direitos (art. 18): consulta, exportação e exclusão em "Meus dados".

RESULTADOS

162	15	3
testes automatizados	riscos mapeados na matriz, nenhum crítico	varreduras de segurança a cada commit

Os cinco blocos de requisitos de segurança foram implementados.

CONCLUSÃO

O Health In Sight mostrou que dá para oferecer informação de saúde útil coletando o mínimo de dados pessoais. As escolhas de segurança seguem normas reconhecidas, como as RFC 9106 e 6238 e o NIST SP 800-38D. Como próximos passos, queremos ampliar o acervo com mais condições e fontes e continuar evoluindo os controles a partir da análise de riscos.

REFERÊNCIAS

BIRYUKOV, A. et al. RFC 9106: Argon2 memory-hard function for password hashing and proof-of-work applications. IETF, 2021.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, 2018.

DWORKIN, M. NIST SP 800-38D: recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC. NIST, 2007.

M'RAIHI, D. et al. RFC 6238: TOTP: time-based one-time password algorithm. IETF, 2011.

OWASP FOUNDATION. OWASP Top 10: 2021. 2021.

RESCORLA, E. RFC 8446: the Transport Layer Security (TLS) protocol version 1.3. IETF, 2018.

SCHNEIER, B.; KELSEY, J. Secure audit logs to support computer forensics. ACM Transactions on Information and System Security, v. 2, n. 2, p. 159-176, 1999.

CAPES · FAPESP · CNPq Conselho Nacional de Desenvolvimento Científico e Tecnológico · UMC Universidade · Pós UMC Universidade